

AUDSPECT

Breach & Attack Simulation Platform

Adversary Simulation Assessment Report

SEBI CSCRF-MII Continuous Control Validation (Three-Tier)

RISK: CRITICAL

Prepared for	DESKTOP-5TVEBSI
Endpoint	Windows/amd64 (10.0.19045)
Environment	Production
Assessment date	10 June 2026, 11:32 UTC
Report generated	10 June 2026, 11:32 UTC
Run reference	18b7b4f8

1. Executive Summary

This report presents the results of an automated breach & attack simulation executed against DESKTOP-5TVEBSI (Windows/amd64 (10.0.19045)) on 10 June 2026. The assessment ran 27 MITRE ATT&CK-aligned techniques to measure how effectively the endpoint's security controls prevent real adversary behaviour.

Of the techniques executed, 11 were prevented or blocked by a security control and 16 executed successfully without being stopped. This yields a prevention effectiveness of 40% and an overall risk classification of Critical (risk score 100/100). Consecutive failures across adjacent kill-chain phases amplified exposure by 1.8×, indicating an attacker could chain multiple steps with limited resistance.

14 critical or high-severity technique(s) were not prevented and require prioritised remediation (see Key Findings). Testing exercised 86% of the ATT&CK enterprise kill chain; broadening scenario coverage in future runs will increase assurance. Prioritised recommendations are provided in section 7.

Overall posture: Critical (risk score 100 / 100, Baseline)

27 techniques · 11 prevented · 16 succeeded · 0 errored · 0 skipped · 14 critical/high finding(s)

2. Assessment Scorecard



3. Methodology & Scope

Framework	MITRE ATT&CK (Enterprise)
Engines	Custom checks
Target endpoint	DESKTOP-5TVEBSI — Windows/amd64 (10.0.19045)
Environment	Production
Techniques executed	27
Tactics exercised	4 of 14 ATT&CK tactics
Window	10 Jun 2026 11:32 UTC

Each technique is scored as PASS when a security control prevented or blocked it, FAIL when it executed without being stopped, ERROR when the test itself could not execute correctly (malformed content, timeout, missing prerequisite, scheduler contention), or SKIPPED when it was not run. Only PASS and FAIL count toward the score: a FAIL is a finding — the simulated adversary behaviour succeeded against this endpoint — while ERROR and SKIPPED are excluded because they reflect a test-execution problem, not the endpoint's defences.

4. ATT&CK Tactic Breakdown

Defense Evasion		50%	2 pass · 2 fail
Credential Access		0%	0 pass · 2 fail

5. Key Findings

HIGH

F-01 T1021.002 — SMB Signing Required

Lateral Movement

What happened

RequireSecuritySignature = 0x0 — SMB relay attacks possible.

Remediation

Set HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters\RequireSecuritySignature = 1.

HIGH

F-02 T1557.001 — LLMNR/NetBIOS Poisoning

Lateral Movement

What happened

LLMNR not disabled via GPO — susceptible to credential capture via Responder/Inveigh.

Remediation

Disable LLMNR via GPO: Computer Config . DNS Client . Turn off multicast name resolution.

HIGH

F-03 T1486 — BitLocker Disk Encryption (C: Drive)

Impact

What happened

BitLocker OFF for C: — plaintext disk accessible if drive is removed, enabling double-extortion.

Remediation

Enable BitLocker on all drives via GPO: Computer Config . Windows Settings . BitLocker Drive Encryption.

HIGH

F-04 T1562.002 — Security Event Log Retention Capacity (CSCRF-3.1)

Cscrf Data Security

What happened

Security log max size = 20MB — critically small, logs overwrite rapidly. SEBI CSCRF non-compliant.

Remediation

Set Security log max size . 1GB via GPO. Forward logs to SIEM with 12-month retention for CSCRF compliance.

HIGH

F-05 T1059.001 — PowerShell Script Block Logging

Defense Evasion

What happened

Script Block Logging not configured — PowerShell attack activity not logged to Event ID 4104.

Remediation

Enable via GPO: Computer Config . PS . Script Block Logging . Enabled.

CRITICAL

F-06 T1490 — VSS Shadow Copy Availability

Impact

What happened

No VSS shadow copies exist — ransomware recovery impossible without external offline backup.

Remediation

Enable automatic VSS on all volumes. Maintain offline/immutable backups per RBI BCP guidelines.

HIGH

F-07 T1082 — Patch Currency — Last Update Age (CSCRF-5.1)

Cscrf Business Continuity

What happened

Last patch installed 198 days ago — significantly overdue, high vulnerability exposure, CSCRF non-compliant.

Remediation

Enforce patch deployment via WSUS/SCCM/Intune. Set 30-day SLA for critical patches per CSCRF schedule.

CRITICAL

F-08 T1486 — Controlled Folder Access (Ransomware Protection)

Impact

What happened

Controlled Folder Access DISABLED — ransomware can encrypt Documents/Desktop/Pictures without restriction.

Remediation

Enable: Windows Security . Virus & Threat Protection . Ransomware Protection . Controlled Folder Access ON.

HIGH

F-09 T1091 — USB/Removable Device Autorun Policy

Cscrf Third Party Risk

What happened

AutoRun not disabled for all drive types — USB device autorun attacks possible. SEBI CSCRF removable-media control non-compliant.

Remediation

Disable AutoRun via GPO: Computer Config . Security . NoDriveTypeAutoRun = 0xFF (all drive types).

HIGH

F-10 T1070.006 — Time Synchronisation (W32tm/NTP) Confidential · Critical · CSCRf-MII Continuous Control Validation (Three-Tier)

Cscrf Incident Response

What happened	W32Time service NOT running — NTP synchronisation unavailable. Regulatory and forensic timeline integrity at risk.
Remediation	Configure W32tm: w32tm /config /manualpeerlist:<NTP-SERVER> /syncfromflags:MANUAL /update. Monitor for time drift via EID 37.

CRITICAL

F-11 T1550.002 — LAPS — Local Admin Password Uniqueness

Identity Hardening

What happened	LAPS not detected — local administrator passwords likely identical across workstations. Lateral movement via pass-the-hash scales to the entire estate.
Remediation	Deploy Microsoft LAPS (legacy AdmPwd.dll) or Windows LAPS (built-in Windows 11/Server 2022+). Set rotation interval . 30 days.

HIGH

F-12 T1003.001 — Windows Credential Guard

Credential Access

What happened	VBS not configured — Credential Guard unavailable.
Remediation	Enable Credential Guard via Group Policy: Computer Config . Device Guard . Credential Guard.

HIGH

F-13 T1558.004 — NTLM Relay Restrictions

Credential Access

What happened	RestrictNTLM not configured — NTLM relay attacks not prevented.
Remediation	Configure HKLM\SYSTEM\CurrentControlSet\Control\Lsa\RestrictNTLMInDomain and enable EPA.

HIGH

F-14 T1003.005 — Cached Domain Logon Credential Count

Cscrf Identity Security

What happened	CachedLogonsCount = 10 — 10 extractable cached credential set(s). SEBI CSCRf MII requires .1.
Remediation	Set CachedLogonsCount = 1 via GPO: Computer Config . Security . Interactive Logon: Number of previous logons to cache.

6. Detailed Technique Results

PASS

T1046 — Open Management Ports (CSCRf-1.1)

Cscrf Network Security · Critical

Details	No high-risk management ports (Telnet/RDP/WinRM/NetBIOS) exposed on all interfaces — CSCRf-1.1 compliant.
Threat impact	SEBI CSCRf requires all unnecessary management interfaces to be closed — open ports are primary attack entry points.
Remediation	Close Telnet(23), restrict RDP(3389) to jump hosts, disable WinRM(5985/5986) if unused. Enforce via Windows Firewall GPO.

PASS

T1562.004 — Windows Firewall Active (All Profiles)

Lateral Movement · High

Details	Windows Firewall enabled on all profiles (Domain, Private, Public).
Threat impact	Disabled firewall removes network access control — unrestricted inbound connections allowed.
Remediation	Enable Windows Firewall on all profiles (Domain, Private, Public) via GPO.

FAIL

T1021.002 — SMB Signing Required

Lateral Movement · High

Details	RequireSecuritySignature = 0x0 — SMB relay attacks possible.
Threat impact	Without SMB signing, relay attacks can authenticate as other users across the network.
Remediation	Set HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters\RequireSecuritySignature = 1.

FAIL

T1557.001 — LLMNR/NetBIOS Poisoning

Lateral Movement · High

Details	LLMNR not disabled via GPO — susceptible to credential capture via Responder/Inveigh.
Threat impact	LLMNR and NetBIOS can be poisoned (Responder) to capture NTLM hashes on local network.
Remediation	Disable LLMNR via GPO: Computer Config . DNS Client . Turn off multicast name resolution.

PASS	T1087.001 — Local Administrator Account Count (CSCRF-2.1)		Cscrf Access Management · High
	Details	1 local administrator(s) — minimal privileged account surface, CSCRF-2.1 compliant.	
	Threat impact	SEBI CSCRF mandates least-privilege — excess local admins widen the blast radius of any compromise.	
	Remediation	Reduce local Administrators to 1 managed account. Deploy Microsoft LAPS for randomised local admin passwords.	
PASS	T1110.001 — Built-in Administrator Account Status (CSCRF-2.2)		Cscrf Access Management · High
	Details	Built-in Administrator account appears disabled or renamed.	
	Threat impact	SEBI CSCRF mandates renaming or disabling the built-in Administrator account to prevent targeted brute-force.	
	Remediation	Disable: Computer Config . Windows Settings . Security Options . Accounts: Administrator account status = Disabled.	
PASS	T1110.001 — Account Lockout Policy (CSCRF-2.3)		Cscrf Access Management · High
	Details	Account lockout configured: Lockout threshold:	10 — brute-force attacks limited per CSCRF-2.3.
	Threat impact	SEBI CSCRF requires account lockout to prevent brute-force attacks against banking system credentials.	
	Remediation	Set via GPO: Lockout threshold . 5 attempts, duration . 30 minutes, observation window . 30 minutes.	
FAIL	T1110 — Password Minimum Length Policy (CSCRF-2.4)		Cscrf Access Management · Medium
	Details	Minimum password length = 0 (no minimum) — SEBI CSCRF requires .12 characters.	
	Threat impact	SEBI CSCRF requires minimum 12-character passwords to resist dictionary and brute-force attacks.	
	Remediation	Set via GPO: Security Settings . Account Policies . Password Policy . Minimum password length = 12.	
FAIL	T1486 — BitLocker Disk Encryption (C: Drive)		Impact · High
	Details	BitLocker OFF for C: — plaintext disk accessible if drive is removed, enabling double-extortion.	
	Threat impact	Unencrypted drives let ransomware operators read all data before encrypting — double-extortion enabled.	
	Remediation	Enable BitLocker on all drives via GPO: Computer Config . Windows Settings . BitLocker Drive Encryption.	
FAIL	T1562.002 — Security Event Log Retention Capacity (CSCRF-3.1)		Cscrf Data Security · High
	Details	Security log max size = 20MB — critically small, logs overwrite rapidly. SEBI CSCRF non-compliant.	
	Threat impact	SEBI CSCRF requires security event retention for forensic investigation — small log sizes cause overwrite within hours.	
	Remediation	Set Security log max size . 1GB via GPO. Forward logs to SIEM with 12-month retention for CSCRF compliance.	
PASS	T1562.001 — Windows Defender Real-Time Protection		Defense Evasion · High
	Details	Windows Defender Real-Time Protection is enabled.	
	Threat impact	Disabled AV/EDR allows malware to execute, persist, and exfiltrate data undetected.	
	Remediation	Enable Defender Real-Time Protection: Settings . Windows Security . Virus & Threat Protection.	
FAIL	T1562.001 — Sysmon Endpoint Monitoring		Defense Evasion · Medium
	Details	Sysmon not installed — limited endpoint visibility for threat hunting.	
	Threat impact	Without Sysmon, process injection, network connections, and file drops are not logged.	
	Remediation	Deploy Sysmon with SwiftOnSecurity or Olaf config on all endpoints.	
FAIL	T1059.001 — PowerShell Script Block Logging		Defense Evasion · High
	Details	Script Block Logging not configured — PowerShell attack activity not logged to Event ID 4104.	
	Threat impact	Without Script Block Logging, malicious PowerShell is executed and exfiltrated unlogged.	
	Remediation	Enable via GPO: Computer Config . PS . Script Block Logging . Enabled.	

PASS

T1070.001 — Windows Event Log Service

SEBI CSCRF-MII Continuous Control Validation (Three-Tier)

Defense Evasion · High

Details	Windows EventLog service is running — audit trail active.
Threat impact	Stopping Event Log lets attackers erase their tracks — no audit trail remains.
Remediation	Ensure EventLog service is locked against non-admin stops. Forward logs to SIEM.

FAIL

T1490 — VSS Shadow Copy Availability

Impact · Critical

Details	No VSS shadow copies exist — ransomware recovery impossible without external offline backup.
Threat impact	Ransomware deletes all shadow copies (vssadmin delete shadows /all) before encrypting — primary recovery path destroyed.
Remediation	Enable automatic VSS on all volumes. Maintain offline/immutable backups per RBI BCP guidelines.

FAIL

T1082 — Patch Currency — Last Update Age (CSCRF-5.1)

Cscrf Business Continuity · High

Details	Last patch installed 198 days ago — significantly overdue, high vulnerability exposure, CSCRF non-compliant.
Threat impact	SEBI CSCRF mandates critical patches within 30 days of release. Unpatched endpoints are primary ransomware entry.
Remediation	Enforce patch deployment via WSUS/SCCM/Intune. Set 30-day SLA for critical patches per CSCRF schedule.

FAIL

T1486 — Controlled Folder Access (Ransomware Protection)

Impact · Critical

Details	Controlled Folder Access DISABLED — ransomware can encrypt Documents/Desktop/Pictures without restriction.
Threat impact	Without CFA, ransomware (LockBit, BlackCat, ALPHV) freely encrypts Documents, Desktop, and Pictures.
Remediation	Enable: Windows Security . Virus & Threat Protection . Ransomware Protection . Controlled Folder Access ON.

PASS

T1219 — Remote Support Tool Inventory

Cscrf Third Party Risk · High

Details	No unmanaged remote support tools detected — SEBI CSCRF remote-access inventory compliant.
Threat impact	SEBI CSCRF requires inventory and control of remote access tools — unmanaged remote support software creates persistent backdoor risk outside vendor oversight.
Remediation	Inventory and formally approve all remote support tools. Enforce AppLocker/WDAC allow-list. Require MFA and session logging for any approved tool.

PASS

T1195 — Unsigned PowerShell Module Detection

Cscrf Third Party Risk · High

Details	All discoverable PowerShell modules have valid signatures — supply-chain integrity maintained.
Threat impact	Unsigned PowerShell modules represent unverified supply-chain code — a vector for persistence and privilege escalation in MII trading environments.
Remediation	Enforce AllSigned execution policy on servers. Audit PSModulePath for unsigned modules. Remove or sign all third-party modules.

FAIL

T1091 — USB/Removable Device Autorun Policy

Cscrf Third Party Risk · High

Details	AutoRun not disabled for all drive types — USB device autorun attacks possible. SEBI CSCRF removable-media control non-compliant.
Threat impact	SEBI CSCRF requires removable media controls — enabled autorun allows physical-access attacks via USB without any user interaction.
Remediation	Disable AutoRun via GPO: Computer Config . Security . NoDriveTypeAutoRun = 0xFF (all drive types).

PASS

T1003.001 — Crash Dump / Forensic Artifact Retention Policy

Cscrf Incident Response · Medium

Details	Automatic memory dump enabled — forensic capture active.
Threat impact	SEBI CSCRF requires forensic artifact retention for regulatory investigations — disabled crash dumps prevent post-incident memory analysis and regulatory review.
Remediation	Enable kernel or minidump: HKLM\SYSTEM\CurrentControlSet\Control\CrashControl\CrashDumpEnabled = 2 (kernel) or 7 (automatic).

FAIL

T1070.006 — Time Synchronisation (W32tm / NTP)

SEBI CSCRF-MII Continuous Control Validation (Three-Tier)

Cscrf Incident Response · High

Details	W32Time service NOT running — NTP synchronisation unavailable. Regulatory and forensic timeline integrity at risk.
Threat impact	SEBI CSCRF and RBI require synchronised time — time skew corrupts forensic timelines, invalidates Kerberos tickets, and breaks regulatory audit trails under investigation.
Remediation	Configure W32tm: w32tm /config /manualpeerlist:<NTP-SERVER> /syncfromflags:MANUAL /update. Monitor for time drift via EID 37.

FAIL

T1550.002 — LAPS — Local Admin Password Uniqueness

Identity Hardening · Critical

Details	LAPS not detected — local administrator passwords likely identical across workstations. Lateral movement via pass-the-hash scales to the entire estate.
Threat impact	Without LAPS, local administrator passwords are identical across all workstations — one compromised machine grants lateral movement to every endpoint at scale.
Remediation	Deploy Microsoft LAPS (legacy AdmPwd.dll) or Windows LAPS (built-in Windows 11/Server 2022+). Set rotation interval . 30 days.

FAIL

T1003.001 — Windows Credential Guard

Credential Access · High

Details	VBS not configured — Credential Guard unavailable.
Threat impact	Without Credential Guard, domain credentials are accessible via LSASS memory dumps.
Remediation	Enable Credential Guard via Group Policy: Computer Config . Device Guard . Credential Guard.

FAIL

T1558.004 — NTLM Relay Restrictions

Credential Access · High

Details	RestrictNTLM not configured — NTLM relay attacks not prevented.
Threat impact	Unrestricted NTLM allows relay attacks to authenticate as domain users without knowing passwords.
Remediation	Configure HKLM\SYSTEM\CurrentControlSet\Control\Lsa\RestrictNTLMInDomain and enable EPA.

FAIL

T1003.005 — Cached Domain Logon Credential Count

Cscrf Identity Security · High

Details	CachedLogonsCount = 10 — 10 extractable cached credential set(s). SEBI CSCRF MII requires .1.
Threat impact	Each cached domain logon stores a hashed credential extractable offline — SEBI CSCRF requires minimising credential exposure on endpoints.
Remediation	Set CachedLogonsCount = 1 via GPO: Computer Config . Security . Interactive Logon: Number of previous logons to cache.

PASS

T1021.001 — RDP Network Level Authentication

Lateral Movement · High

Details	RDP NLA (Network Level Authentication) is enabled.
Threat impact	RDP without NLA exposes the login screen before authentication — enables pre-auth exploitation.
Remediation	Enable NLA: HKLM\...\RDP-Tcp\UserAuthentication = 1, or via System Properties . Remote.

7. Prioritised Recommendations

- Overall prevention score is critically low. Prioritise endpoint hardening and EDR deployment across all assets.
- Critical tactic 'credential-access' has 2 failing technique(s). Address immediately — this tactic has the highest attacker value in BFSI environments.
- Critical tactic 'lateral-movement' has 2 failing technique(s). Address immediately — this tactic has the highest attacker value in BFSI environments.
- Kill-chain amplifier is 1.8× — an attacker can traverse multiple consecutive kill-chain phases unimpeded. Implement network segmentation and lateral movement controls.
- Exposure score exceeds 60. Deploy a 24×7 SOC with SIEM correlation rules aligned to detected failure patterns.

8. Appendix — Metric Definitions

PASS	A security control prevented or blocked the simulated technique. More passes is better.
FAIL	The technique executed successfully without being stopped — a finding requiring attention.
ERROR	The test could not execute correctly (malformed content, timeout, missing prerequisite, scheduler contention). A BAS execution problem, not a security outcome — excluded from scoring.
SKIPPED	The technique was deliberately not run (e.g. external payload not shipped) and was excluded from scoring.
Prevention	Severity-weighted percentage of techniques that were prevented. Higher is better.
Exposure	Tactic-weighted failure rate, amplified by consecutive kill-chain failures. Lower is better.
Tactic Coverage	Breadth of testing: how many of the 14 MITRE ATT&CK Enterprise tactics this run exercised.
Defense Rate	Share of tested tactics in which every technique was blocked (zero failures).
Kill-chain amplifier	Multiplier (1.0–2.5×) reflecting consecutive unprevented kill-chain phases.
Risk classification	Overall posture band derived from the amplified exposure score.